로그인·보안 / 데이터 증가 대비 점검 목록

버스 혼잡도 예측 및 불편 신고접수 시스템 | 점검일 2026-10-28 | 기준: dev 브랜치(`7426caf`)의 코드와 팀 DB 메타정보 (운영 환경의 HTTPS·서버 설정은 점검하지 못함)

한눈에 보기

- 기본기는 갖춰져 있음: BCrypt 암호화, 서버 쪽 입력 검증, SQL 인젝션 방어, 관리자 화면 접근 제한, 본인 신고만 접근
- 가장 먼저 막아야 할 것 3가지: **관리자 API 접근 제한 없음**, **업로드 파일 주소가 비로그인으로 열림**, **CSRF 방어 없음**
- 데이터가 늘면 문제가 될 것: 신고 내용 검색(`LIKE '%…%'`), 신고 테이블 인덱스 부족, 실시간 통계 집계
- 팀에서 정해야 할 것: 인증 방식(현재 방식 유지·보완 vs Spring Security 도입), 노선 번호 기준, 업로드·개인정보 정책

우선순위: **상** = 지금 노출·악용 가능, **중** = 서비스 전에 해결, **하** = 규모가 커지거나 운영 시 해결

1. 로그인·보안

1-1. 마련된 것

항목	내용 (근거)
비밀번호 암호화	BCrypt 사용. DB의 회원 7명 모두 BCrypt 형식으로 저장됨
서버 쪽 입력 검증	아이디·비밀번호·이름·전화번호 형식을 서버에서 다시 검사 (화면 JS를 우회해도 막힘)
아이디 중복 방지	중복 확인 + DB 유니크 제약(`UK_MEMBER_ID`) + 동시 가입 예외 처리
계정 존재 여부 비노출	아이디가 틀려도 비밀번호가 틀려도 같은 오류 문구 표시
세션에 비밀번호 미저장	로그인 성공 시 비밀번호 값을 비우고 세션에 저장
관리자 화면 접근 제한	관리자 컨트롤러 3개의 모든 메서드(GET·POST)가 `AdminUtil.checkAdmin` 호출. 비로그인은 로그인으로, 일반 회원은 메인으로 이동
본인 신고만 접근	신고 상세·수정·삭제를 로그인 회원 번호와 함께 조회
신고 중복 제출 방지	일회용 토큰(`reportToken`)
SQL 인젝션 방어	MyBatis 쿼리가 모두 `#{}` 사용, 정렬도 고정 SQL로 분기
검색 조건 정리	상태·정렬·페이지 크기는 허용값만, 검색어 길이 제한
업로드 기본 방어	확장자 허용 목록, 총 200MB 제한, 저장 파일명은 UUID(원본 이름 미사용)
지도 기능	노선번호 형식 검사, 카카오 REST 키는 서버에만 보관, 호출 시간 제한, 실패 시 직선으로 대체

1-2. 마련되지 않은 것

#	우선순위	항목	설명	해결 방향
1	상	관리자 API 접근 제한 없음	`/admin/api/**`가 로그인 없이 열려 있음. 지도 데이터가 노출되고, `/road`는 카카오 하루 1,000건 한도를 소모할 수 있음	관리자 확인 추가 (작은 작업). 이후 Interceptor로 통합

2	**상**	업로드 파일 주소가 비로그인으로 열림	`/upload/**`를 인증 없이 서빙. 주소를 알면 신고 사진·영상 열람 가능 (UUID라 추측은 어렵지만 개인정보가 담길 수 있음)	로그인·본인·관리자 확인 후 내려주는 방식으로 변경
3	**상**	CSRF 방어 없음	토큰은 신고 접수에만 있음. 관리자 신고 처리·노선 추가·삭제, 신고 수정·삭제는 로그인 상태에서 외부 사이트의 위조 요청에 노출될 수 있음	CSRF 토큰 도입 (Spring Security 도입 시 기본 제공)
4	**중**	로그인 시 세션 ID 교체 없음	로그인해도 기존 세션을 그대로 사용 (세션 고정 공격 가능)	로그인 성공 시 세션 ID 교체
5	**중**	로그인 시도 제한 없음	비밀번호 무차별 대입을 막지 못함. 비밀번호 규칙도 영문+숫자 8~20자로 특수문자 불가	실패 횟수 제한·잠금, 비밀번호 규칙 보완
6	**중**	관리자 확인이 메서드마다 직접 호출	새 관리자 화면에서 호출을 빼먹으면 구멍이 생김 (코드에 "Interceptor로 바꿀 것" 메모 있음)	`/admin/**` 일괄 Interceptor 또는 Spring Security
7	**중**	DB 계정 권한 과다	앱이 쓰는 계정이 `project-3` 전체 권한(`WITH GRANT OPTION`)과 `project-2` 권한까지 보유	앱용 계정은 필요한 권한만, 관리용 계정과 분리
8	**중**	개인정보 로그·보관 정책	SQL 로그(log4jdbc)에 전화번호 등 파라미터가 남을 수 있음. 신고자 이름·전화번호 보관 기간·파기 정책 없음	로그 마스킹·레벨 조정, 보관 기간 정책 수립
9	**하**	쿠키·세션·HTTPS 설정	쿠키 `Secure`·`SameSite`, 세션 만료 시간 미설정. 로그아웃이 GET 방식. HTTPS 미적용(개발 환경)	운영 전 설정, 로그아웃을 POST로 변경
10	**하**	업로드 내용 검사·관리자 승격 절차	확장자만 검사하고 파일 내용(MIME)은 보지 않음. 관리자 지정은 DB 직접 수정으로만 가능	내용 검사, 관리자 지정 절차 마련

2. 데이터가 많아질 때

2-1. 마련된 것

항목	내용
목록 페이징	신고 목록 `LIMIT/OFFSET` 페이징, 페이지 크기는 10·20·50만 허용
검색 결과 제한	노선 검색은 최대 50건, 검색어 길이 제한
기본 인덱스·제약	PK, 아이디 유니크, 외래키 4개(신고↔회원, 신고↔유형, 첨부↔신고, 유형↔유형그룹)
지도 표시 최적화	정류장 점은 화면에 보이는 것만 그림, 도로 선은 보이는 방향만 요청

2-2. 마련되지 않은 것

#	우선순위	항목	설명	해결 방향
1	중	신고 내용 검색	`CONTENT LIKE '%검색어%'` 는 인덱스를 못 써서 신고가 늘면 전체를 훑음	풀텍스트 인덱스 또는 검색 엔진
2	중	필터·정렬용 인덱스	`report` 에 `STATUS`, `REG_DATE`, `ROUTE_NO` 인덱스가 없음 (PK와 외래키 인덱스만 있음)	자주 쓰는 조건에 복합 인덱스 추가
3	중	`report.ROUTE_NO` 외래키 없음	`bus_route` 에 없는 노선(`713`)이 신고에 들어가 있음. 노선 번호 정합성을 DB가 보장하지 못함	노선 번호 기준 확정 후 외래키 추가
4	중	업로드 저장소	서버 로컬 디스크 한 곳. 용량 관리·삭제 정책·서버 여러 대 공유 없음	저장 위치·보관 정책 결정, 필요 시 외부 저장소
5	중	카카오 호출 한도 관리	호출 속도·동시 호출 제한 없음(저장은 정책상 불가). 하루 1,000건 한도에 사용자가 늘면 부딪힘	관리자 접근 제한, 호출 횟수 제한
6	하	통계 실시간 집계	대시보드를 열 때마다 상태·노선·유형별 건수를 `GROUP BY` 로 계산	캐시 또는 집계 테이블
7	하	깊은 페이지 조회	`OFFSET` 방식이라 뒤쪽 페이지일수록 느려짐	키셋 페이징
8	하	세션 저장 방식	서버 메모리라 재시작하면 로그인이 풀리고, 서버를 여러 대 두면 공유 안 됨	세션 저장소 분리 (서버 증설 시)
9	하	지도: 전체 노선 일괄 로딩	처음에 모든 노선의 선을 한꺼번에 받음. 노선 41개는 문제없지만 수백 개가 되면 느려짐	지연 로딩, 서버 쪽 페이징

3. 확인이 더 필요한 것

항목	내용

업로드 용량 설정	`application.yaml`에 `multipart` 설정이 없음. Spring 기본값(파일 1MB, 요청 10MB)이면 코드가 허용하는 200MB 동영상 첨부가 실제로는 막힐 가능성이 큼 (직접 올려서 확인하지는 않음)
감사 로그	관리자의 신고 처리·노선 삭제 이력을 남기는지 확인하지 못함
운영 환경	HTTPS, 서버·방화벽 설정, 백업 정책은 점검 범위 밖
쓰기 동작	신고 접수·수정·삭제와 관리자 처리·노선 변경은 팀 DB를 바꾸므로 직접 실행하지 않고 코드로만 확인

4. 팀 논의 안건

#	안건	논의 내용
1	인증 방식	① 현재 세션 방식을 유지하고 Interceptor, CSRF 토큰, 세션 ID 교체, 로그인 제한을 직접 보완하거나 ② Spring Security를 도입해 한꺼번에 처리. 도입 시 기존 로그인 코드(`MemberController`, `AdminUtil`)를 바꿔야 하고, 현재는 비밀번호 암호화 모듈만 사용 중
2	노선 번호 기준	`bus_route`를 울산 BIS 노선번호(BRTNO)로 맞추고, 예측 쪽 노선 ID도 같은 번호로 연결. 현재 DB는 서울·경기 샘플 노선 8개라 지도의 울산 노선과 겹치지 않음. `report.ROUTE_NO` 외래키도 함께 결정
3	업로드 파일 정책	접근 권한(본인·관리자만), 허용 용량, 저장 위치, 보관·삭제 기간
4	개인정보 정책	신고자 이름·전화번호의 보관 기간과 파기, SQL 로그에 남는 값 처리
5	카카오 호출 한도	하루 1,000건 무료. 관리자만 호출하도록 제한하고, 팀원 키 공유 방식(각자 발급 vs 공유) 결정

5. 권장 진행 순서

단계	작업
1단계: 지금 (작은 작업)	관리자 API 접근 제한, 업로드 파일 접근 제한, 로그인 시 세션 ID 교체, 업로드 용량 설정 확인
2단계: 팀 결정 후	인증 방식 결정(Interceptor 또는 Spring Security) → CSRF, 로그인 시도 제한, 접근 제한 일괄 적용. DB 계정 권한 정리, 개인정보 로그·보관 정책
3단계: 데이터가 모이면	노선 번호 기준 확정과 외래키, 신고 테이블 인덱스, 신고 내용 검색, 통계 캐시, 업로드 저장소